RISKTECH & ADVISORY · EXECUTIVE PLATFORM

Executive Onboarding & Vetting Portal

Technical design pack

29 October 2026

1. Architecture

2. Data model

2.1 Data dictionary

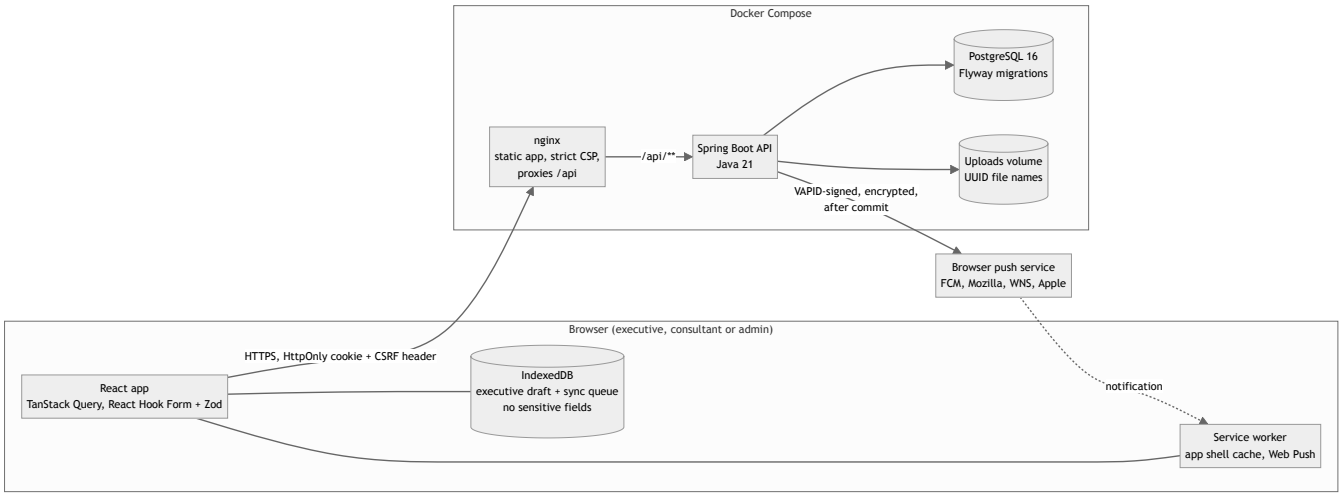
3. Technology choices

4. Risk register

Appendix A. Roles and permissions

1. Architecture

Three containers run under Docker Compose. The browser only ever talks to nginx, so the app and the API share one origin: the session cookie can be `SameSite=Strict` and no CORS exceptions are needed in normal use.



Components

Component	Responsibility
React app	Role-based screens: onboarding wizard, reviewer queue and case page, admin users and audit trail. Server state in TanStack Query; forms validated with Zod before they are sent.
Service worker (`sw.js`)	Caches the built app shell so the app opens offline; never handles `/api`. Shows push notifications.
IndexedDB (Dexie)	The executive's draft and the queue of unsent step saves. National ID and referee contacts are never written here.
nginx	Serves the static build with security headers (CSP, frame denial, nosniff, no referrer) and proxies `/api` to the backend.
Spring Boot API	Authentication, authorisation, validation, business rules, encryption, audit, push. Packages by feature: `auth`, `user`, `onboarding`, `consent`, `document`, `vetting`, `audit`, `notification`, plus `config` and `common`.
PostgreSQL	Users, onboarding drafts (JSONB), submitted profile tables, documents metadata, vetting cases and notes, consents, the hash-chained audit log, push subscriptions, idempotency keys.
Uploads volume	Document files, stored under random UUID names outside any web root; reachable only through authorised download endpoints.

How a request is handled

1. The browser sends the `EXEC_AUTH` cookie (HttpOnly, SameSite=Strict) and, for writes, the `X-XSRF-TOKEN` header.
2. Spring Security verifies the JWT, then loads the user from the database and compares `token_version`, so logout, password change and deactivation take effect immediately.

3. `@PreAuthorize` checks the role on the controller; the service checks ownership or case visibility. Someone else's record is a 404.
4. DTOs with Bean Validation are the only input and output. Data access is parameterised SQL through `JdbcTemplate`, plus one JPA entity (`User`) that never leaves the service layer.
5. Business changes and their audit entry commit in one transaction. Push notifications are sent only after the commit, on a small bounded thread pool, so a failed push never affects the decision.
6. Expected failures become one JSON error shape (`timestamp`, `status`, `error`, `message`, `path`, `traceId`); no stack traces leave the server.

Trust boundaries

Boundary	What crosses it	Controls
Browser → nginx	Every request	Same origin, strict CSP, HttpOnly cookie, CSRF token
nginx → API	`/api/**` only	Default deny, role checks, ownership checks, validation, rate limiting on sign-in
API → PostgreSQL	Parameterised SQL	Sensitive fields encrypted before storage (AES-256-GCM); audit table append-only by triggers
API → file storage	Validated files	Type from magic bytes, 5 MB limit, UUID names, SHA-256, path containment
API → push service	Fixed generic payload	Endpoint allowlist (SSRF guard), payload has no personal data
Device storage	Non-sensitive draft fields	Keyed to one executive, wiped on sign-out or user change, 12-hour offline window

Main flows

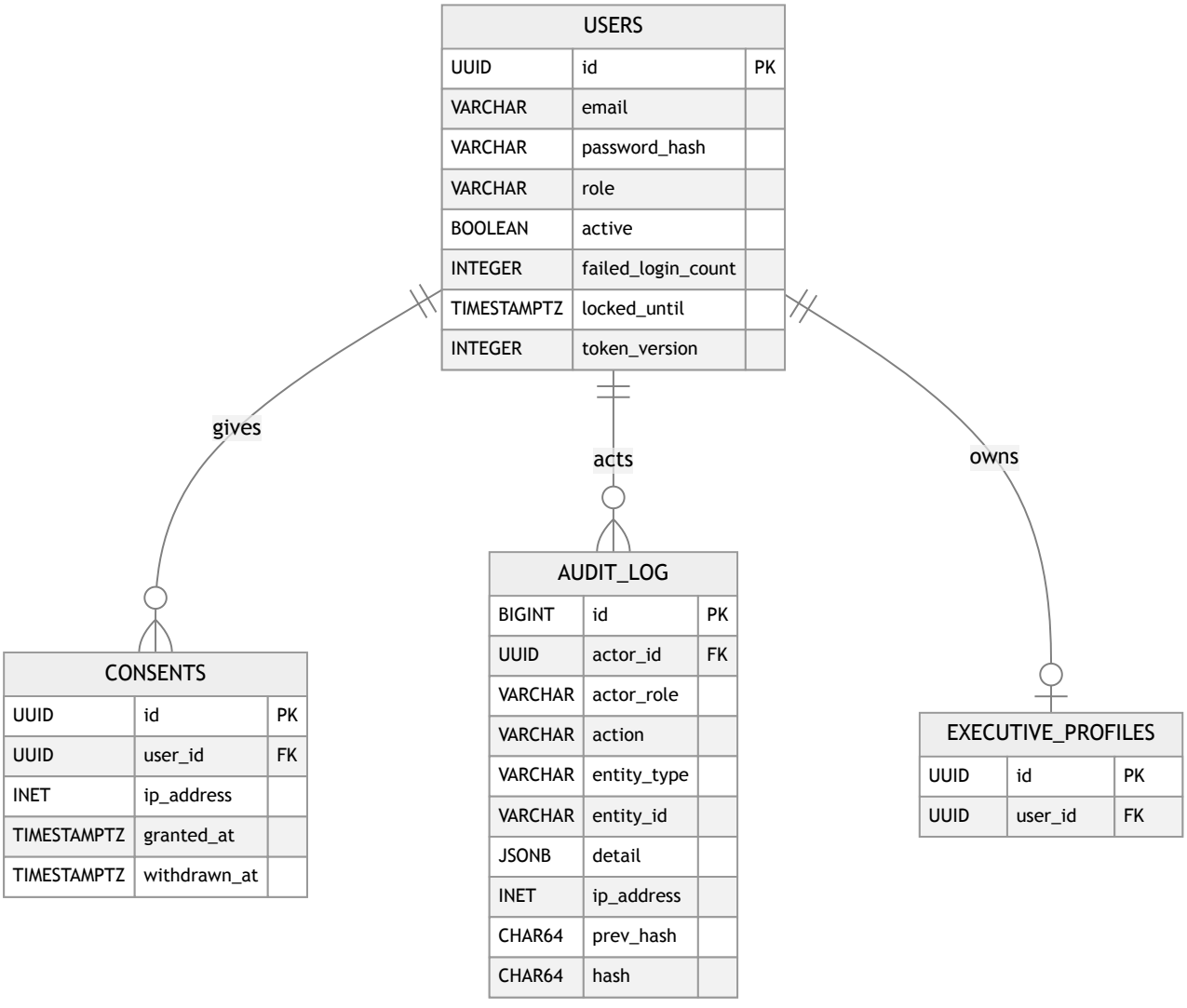
- **Onboarding:** consent first, then five steps saved one at a time (optimistic locking on a draft `version`), then document upload, then submit. Submission validates everything, copies the draft into relational tables and creates the vetting case as `SUBMITTED`.
- **Vetting:** a consultant picks up a case (`UNDER_REVIEW`, now assigned to them), then requests more information, verifies or rejects. The executive can edit and resubmit after a "more information" request. Every transition goes through one table-driven state machine and writes an audit entry.
- **Offline:** each save is written to IndexedDB first and sent by the sync engine with an `Idempotency-Key`, so a retried request is applied once. A stale version opens a "keep mine or use server's" dialog.
- **Audit:** every key action appends a hash-chained entry; admins can verify the chain and read it as sentences.

2. Data model

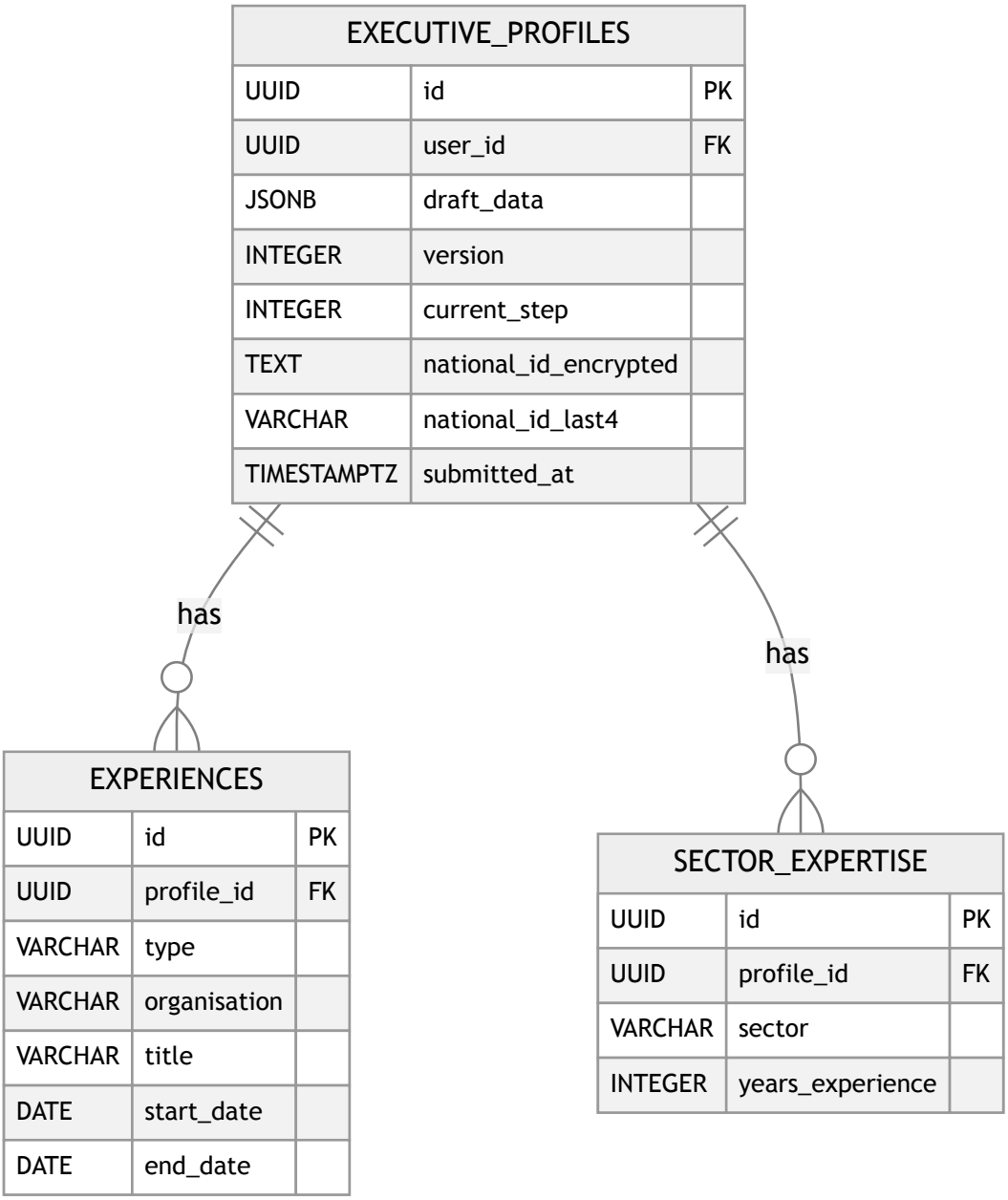
Generated from the Flyway migrations `V1` to `V8`. Shown as five diagrams so the columns stay readable; a table that links two diagrams appears in both, reduced to its key.

Encrypted (AES-256-GCM): `executive_profiles.national_id_encrypted`, `referees.email_encrypted`, `referees.phone_encrypted`. Nullable foreign keys: `vetting_cases.assigned_consultant_id` (no reviewer until pickup) and `audit_log.actor_id` (system events and failed sign-ins).

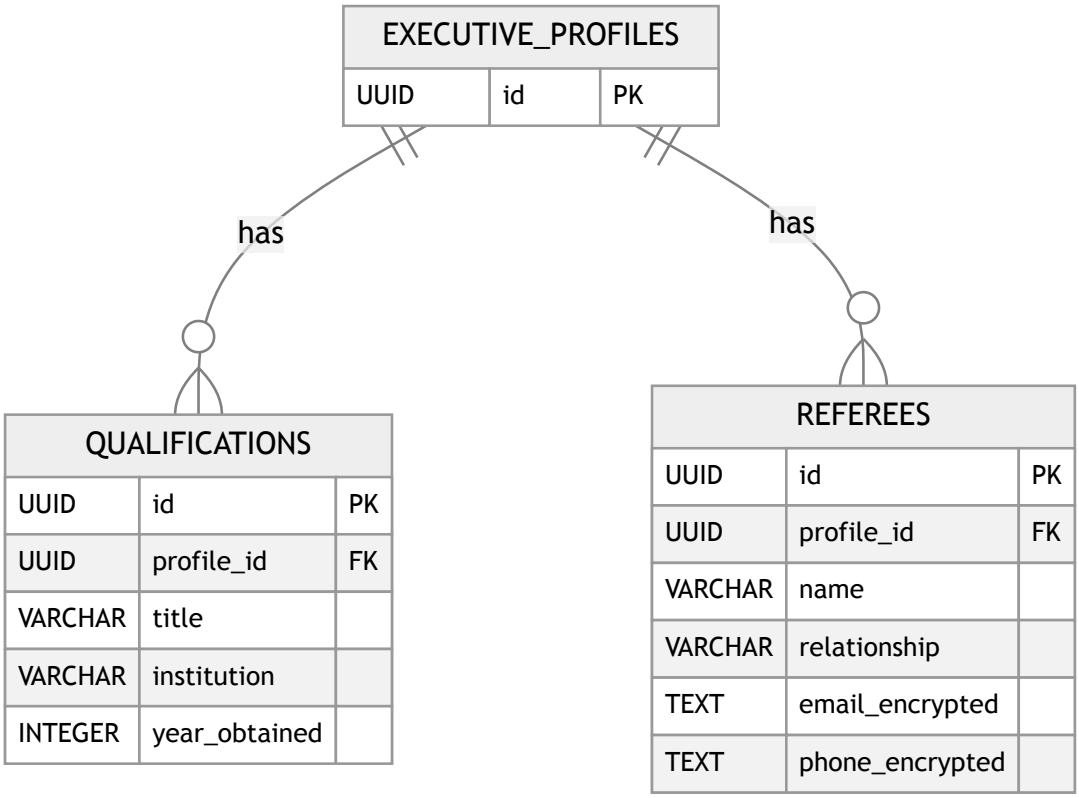
Accounts, consent and audit



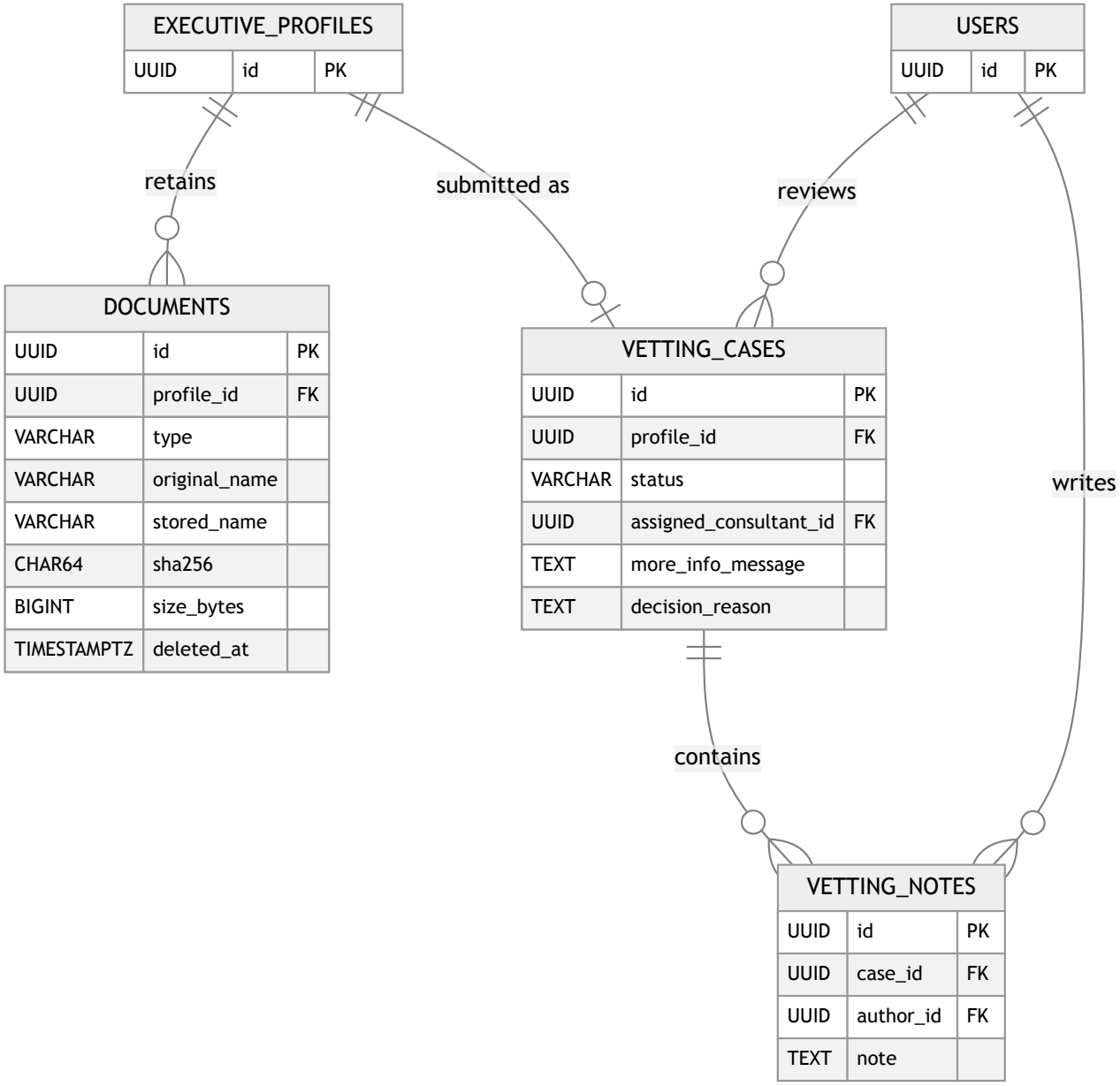
Executive profile: experience and sectors



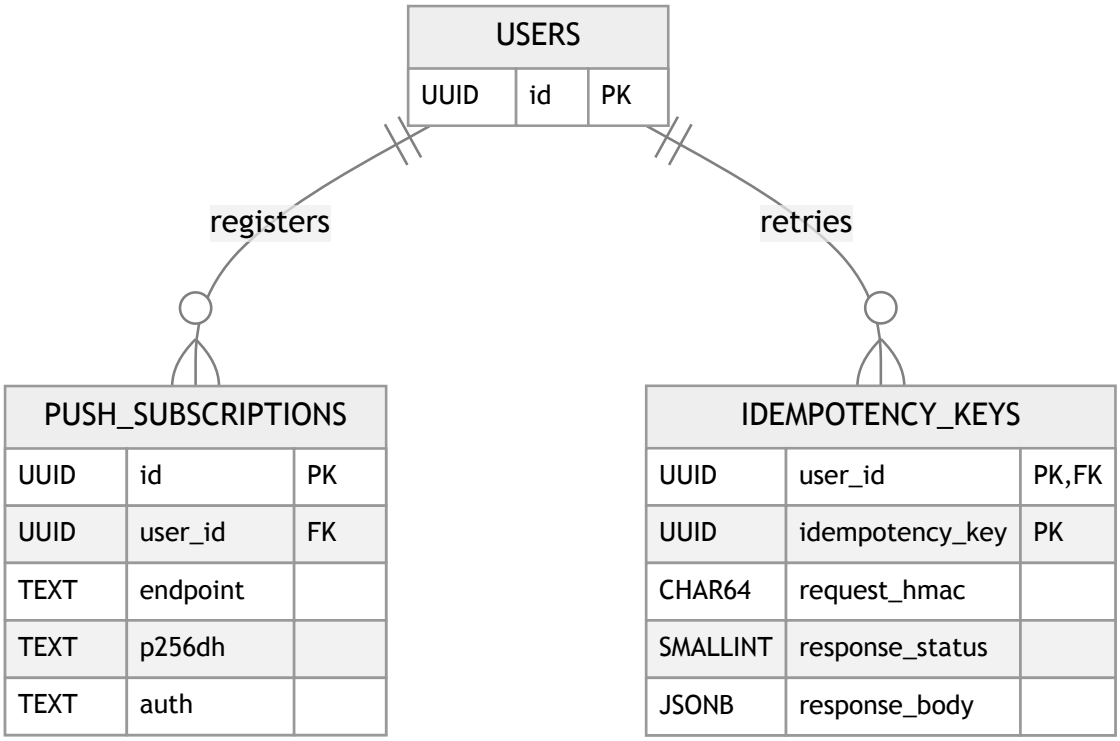
Executive profile: qualifications and referees



Documents and vetting



Devices and offline sync



Every column, type and constraint is listed in the data dictionary.

2.1 Data dictionary

All tables use UUID keys with `gen_random_uuid()` unless noted. `TIMESTAMPTZ` is used for every timestamp. Mutable tables have `created_at` and `updated_at` maintained by `set_updated_at()`; `vetting_notes`, `audit_log`, and `push_subscriptions` intentionally have `created_at` only because they are append-only or insert-or-delete records.

users

Purpose: accounts and lockout state. Columns: `id` UUID PK; `email` VARCHAR required, case-insensitive unique; `password_hash` VARCHAR required; `role` VARCHAR required, EXECUTIVE/CONSULTANT/ADMIN; `active` BOOLEAN default true; `failed_login_count` INTEGER default 0, >=0; `locked_until` TIMESTAMPTZ optional; `token_version` INTEGER default 0, >=0, revokes existing JWTs when incremented; timestamps required/default now. No FKs.

executive_profiles

Purpose: one executive onboarding draft per user. Columns: `id` UUID PK; `user_id` UUID required unique FK users RESTRICT; `draft_data` JSONB default `{}`; `version` INTEGER default 1, >=1 and application-managed; `current_step` INTEGER optional; `submitted_at` TIMESTAMPTZ optional; `national_id_encrypted` TEXT optional 🔒 AES-GCM application field; `national_id_last4` VARCHAR(4) optional 🔒; timestamps. Both national ID columns are filled at submission from the draft (AES-256-GCM ciphertext and the last four characters for masking) and cleared on account deletion.

experiences

Purpose: executive and board experience. Columns: `id` UUID PK; `profile_id` UUID required FK profiles CASCADE; `type` VARCHAR EXECUTIVE/BOARD; `organisation`, `title`, `start_date`, `description` required; `end_date` optional and not before start_date; timestamps.

sector_expertise

Purpose: sector experience. Columns: `id` UUID PK; `profile_id` UUID required FK CASCADE; `sector` VARCHAR required; `years_experience` INTEGER required >=0; timestamps; unique `(profile_id, sector)`.

qualifications

Purpose: qualifications. Columns: `id` UUID PK; `profile_id` UUID required FK CASCADE; `title`, `institution` required VARCHAR; `year_obtained` INTEGER required 1900–2100; timestamps.

referees

Purpose: minimum referee information for vetting. Columns: `id` UUID PK; `profile_id` UUID required FK CASCADE; `name`, `relationship` required; `email_encrypted`, `phone_encrypted` required TEXT 🔒 and

AES-GCM application fields; timestamps.

documents

Purpose: document metadata and retention. Columns: `id` UUID PK; `profile_id` UUID required FK RESTRICT; `type` CV/ID/CERTIFICATE; `original_name`, `stored_name`, `content_type` required; `size_bytes` BIGINT >0; `sha256` CHAR(64) lowercase hex; `uploaded_at` default now; `deleted_at` optional; timestamps; `identification_type` VARCHAR(40) and `certification_name` VARCHAR(160) optional labels. `stored_name` is unique and server-generated. Soft deletion preserves retention records.

vetting_cases

Purpose: one non-reopenable case per profile. Columns: `id` UUID PK; `profile_id` UUID required unique FK RESTRICT; `status` required DRAFT/SUBMITTED/UNDER_REVIEW/MORE_INFO_REQUIRED/VERIFIED/REJECTED; `assigned_consultant_id` optional FK users RESTRICT; `more_info_message`, `decision_reason`, `submitted_at`, `decided_at` optional; rejection and more-info checks; timestamps. State transitions belong to the application.

vetting_notes

Purpose: consultant-only review notes. Columns: `id` UUID PK; `case_id` required FK RESTRICT; `author_id` required FK users RESTRICT; `note` required; `created_at` only because append-only. Never expose to executives.

consents

Purpose: consent evidence. Columns: `id` UUID PK; `user_id` required FK RESTRICT, unique together with `withdrawn_at`; `ip_address` INET optional; `granted_at` default now; `withdrawn_at` optional and not before granted_at; timestamps. A row means consent was given; withdrawal timestamps the same row; re-consent creates a new row. This table remains mutable for withdrawal, hence both timestamps.

audit_log

Purpose: append-only, hash-chained audit records. Columns: `id` BIGINT identity PK for strict ordering; `actor_id` optional FK users RESTRICT for system/failed-login actions; `actor_role` optional role check; `action` required; `entity_type`, `entity_id`, `detail`, `ip_address` optional; `created_at`; `prev_hash` and unique `hash` CHAR(64) lowercase hex. No updated_at because immutable. Detail must not contain sensitive payloads. Three triggers reject update, delete, and truncate.

push_subscriptions

Purpose: authenticated user push endpoints. Columns: `id` UUID PK; `user_id` required FK users CASCADE; `endpoint`, `p256dh`, `auth` required and endpoint unique; `created_at` only because subscriptions are insert-or-delete records.

idempotency_keys

Purpose: replay protection for offline sync of onboarding step saves. Columns: composite PK (`user_id`, `idempotency_key` UUID); `user_id` FK users CASCADE; `request_hmac` CHAR(64) lowercase hex (HMAC-SHA256 of the canonical request, keyed with a subkey of `ENCRYPTION_KEY`); `response_status` SMALLINT; `response_body` JSONB holding only `{version, currentStep, stepStatus}`; `created_at` only, because rows are insert-only. Index on `created_at` for the hourly purge (rows older than `IDEMPOTENCY_TTL_HOURS`, default 168). Rows are also deleted when an executive deletes their account.

Indexes cover all FK columns; unique constraints/composite indexes cover `executive_profiles.user_id`, `sector_expertise.profile_id`, `vetting_cases.profile_id`, and the two vetting-case composite FK/status access paths. No redundant standalone indexes were added for those covered leading columns.

3. Technology choices

The guiding rule: mature, well-understood tools that I can explain line by line, and as few dependencies as the requirements allow. Every security control lives on the server; the frontend only improves the experience.

Stack

Layer	Choice	Why	Alternatives considered
Backend	Java 21, Spring Boot 3.3	Spring Security gives tested building blocks for cookie-based JWT, CSRF and method-level authorisation; Bean Validation and transactions are built in. Widely used in regulated industries.	Node/NestJS: fewer batteries for security and transactions.
Data access	`JdbcTemplate` with plain SQL (one JPA entity for `User`)	Queries are visible and reviewable, always parameterised; row locks (`FOR UPDATE`) and JSONB are explicit.	Full JPA mapping: hides the SQL that matters for locking and audit.
Database	PostgreSQL 16	JSONB for the editable draft, CHECK constraints, triggers for an append-only audit table, advisory locks, `inet` type.	MySQL: weaker JSON and trigger story.
Migrations	Flyway	Ordered, reviewed SQL; the same schema everywhere; easy to read in a review.	Hibernate auto-DDL: not reviewable.
Frontend	React 18, TypeScript (strict), Vite	Strict typing catches contract mistakes; Vite builds fast with no configuration.	Next.js: server rendering is not needed for an authenticated app.
Server state	TanStack Query	Caching, refetch on focus and invalidation after mutations without hand-written stores.	Redux: more code for the same result.
Forms	React Hook Form + Zod	Per-step schemas give instant, specific messages; the server still validates everything.	Hand-written validation: inconsistent messages.
Styling	Design tokens in plain CSS, no UI library	Small bundle, full control over accessibility and focus states, nothing to audit.	Component libraries: heavy for a handful of screens.
Offline storage	Dexie 4 (IndexedDB)	A small, typed wrapper over IndexedDB, behind a `LocalStore` interface so tests use memory.	localStorage: synchronous, small, and readable by any script.
Service worker	Hand-written `sw.js` (about 100 lines)	Caches only the app shell and handles push; easy to show that it never touches `/api`.	Workbox / vite-plugin-pwa: more dependencies than the problem needs.
Push	`web-push` 5.1.1 (Java) + BouncyCastle	Standard VAPID and payload encryption. Only `PushService` is used; the Netty client and CLI are excluded and old transitive dependencies are pinned to patched versions.	A hosted push vendor: personal data leaves our control.
Local run	Docker Compose with nginx in front	One command starts the whole stack; nginx keeps the browser same-origin and adds security headers.	Running services by hand: harder for reviewers.

Layer	Choice	Why	Alternatives considered
Tests	JUnit 5, Testcontainers (real PostgreSQL), MockMvc; Vitest + React Testing Library	Integration tests run against the same database engine as production, including triggers and locks.	H2 in-memory: would not test JSONB, triggers or locks.

Security design choices

Decision	Why	Trade-off accepted
JWT in an HttpOnly, SameSite=Strict cookie, plus a CSRF token	JavaScript cannot read the session; cross-site requests cannot use it.	A CSRF header must accompany every write.
User and `token_version` loaded on every request	Logout, password change and deactivation revoke all sessions at once, without a denylist.	One database read per request.
BCrypt (strength 12)	Built into Spring Security and well understood.	Argon2 would need extra configuration for little benefit here.
Lockout after 5 failures for 15 minutes, per-IP limit	Slows brute force and credential stuffing.	Someone can lock a known account for 15 minutes; the limiter is per instance.
404 for records you may not see	Does not confirm that another person's case or document exists.	Slightly less helpful errors.
Application-level AES-256-GCM for national ID and referee contacts	Database dumps and backups do not expose them; each field has its own context so values cannot be swapped.	Key rotation is not implemented.
Masked values mean "keep"	The form can show that a value is on file without ever sending it back to the browser in full.	The client and server share a small contract (missing = remove, masked = keep).
Table-driven vetting state machine	One place lists every allowed transition, who may make it and what it requires; everything else is a 409.	New transitions need a code change (intended).
Admins are read-only on cases	Separation of duties: the person who manages accounts cannot also decide cases.	An admin cannot cover for an absent consultant without a reassignment feature.
Consultants see only cases awaiting pickup and their own	Least privilege: a case's documents and referee contacts are visible only to consultants who can access it (awaiting pickup, or assigned to them) and to admins, read-only. Once a case is picked up, other consultants get 404. The national ID is always masked for reviewers.	Covering for a colleague needs reassignment (not built).
Hash-chained audit log with database triggers	Edits and deleted rows are detectable; ordinary updates and deletes are refused.	A database owner could rewrite the whole chain; external anchoring is production work.
Push payload is a fixed sentence	Lock screens and push operators learn nothing about the case.	The executive must sign in to see what changed.

Decision	Why	Trade-off accepted
Push sent after commit, asynchronously	A rolled-back decision never notifies; a slow push service never slows the reviewer.	Best effort: no retry.
Sensitive fields never stored offline	IndexedDB is not encrypted; encrypting it would leave the key on the same device.	Those fields need a connection.
Idempotency keys for offline saves	A retried save after a lost response is applied once.	One small table, purged after 7 days.

Scope choices

Done fully: the six core features, push notifications and offline editing. Deliberately left for production (and listed in the README): consent versioning, consent withdrawal and data export, MFA, password reset, case reassignment and reopening, real virus scanning, object storage, and a least-privilege runtime database user.

4. Risk register

The main security and privacy threats to a portal that holds executives' identity documents, referee contacts and vetting decisions. Likelihood (L) and impact (I) are rated High / Medium / Low **before** mitigation. "Evidence" names the automated test that proves the control, or "manual" where it was checked by hand.

Security

#	Threat	L	I	Mitigation in this PoC	Evidence	Residual risk
S1	Brute force and credential stuffing on sign-in	H	H	BCrypt (12); lockout after 5 failures for 15 minutes; 20 sign-ins per minute per IP; one generic "invalid credentials" message	manual	Distributed attacks bypass a per-IP limit; an attacker can lock a known account for 15 minutes. Production: MFA, adaptive throttling at the edge
S2	Session theft through XSS	M	H	Session JWT only in an HttpOnly cookie; strict same-origin CSP from nginx and the API; React escapes output; no tokens in web storage	manual	A future XSS bug could still act as the user while the page is open
S3	Cross-site request forgery	M	H	SameSite=Strict cookie plus a CSRF token cookie/header pair on every write	`StaleSessionIntegrationTest` (sign-in with CSRF), manual	None significant while both controls stay in place
S4	Stolen or stale sessions	M	H	60-minute JWT; the user and `token_version` are reloaded on every request, so logout, password change and deactivation end every session	`StaleSessionIntegrationTest`	No per-device sign-out; JWT secret rotation is manual

#	Threat	L	I	Mitigation in this PoC	Evidence	Residual risk
S5	Broken access control: reading another person's data (IDOR)	H	H	Deny by default; `@PreAuthorize` on every endpoint; ownership checked in services; consultants see only cases awaiting pickup and their own; other records are 404	`VettingIntegrationTest` (`consultantsSeeOnly…`, `executivesHaveNoReviewerAccess`, `caseDocumentDownloadIsScopedToTheCase`), `DocumentDeleteIntegrationTest`	A new endpoint that forgets the service check; mitigated by the single `canSee` rule and review
S6	Privilege misuse: an admin or consultant changing outcomes they should not	M	H	Table-driven state machine; only the assigned consultant can change status; admins are read-only on cases; admins cannot deactivate themselves; every transition audited	`VettingStateMachineTest`, `VettingIntegrationTest` (`adminIsReadOnly`, `pickingUpAssigns…`)	Cases of a deactivated consultant are stuck until reassignment is built
S7	Malicious file upload (malware, script disguised as an image, path traversal)	H	H	Type detected from magic bytes (PDF, JPG, PNG) and matched to the extension; 5 MB limit in Spring and the app; random UUID file names outside any web root; path containment check; downloads only as attachments with `nosniff`; SHA-256 stored	manual	No real virus scan (documented stub). Production: AV scanning and object storage

#	Threat	L	I	Mitigation in this PoC	Evidence	Residual risk
S8	Tampering with the audit trail	M	H	Append-only table enforced by triggers; each entry hash-chained to the previous one; admin chain verification reports the first broken link	`SchemaMigrationTest` (`auditLogIsAppendOnly`), manual verification	A database owner can drop triggers and rebuild the chain; deleting the newest entries is undetectable without an external anchor. Production: least-privilege runtime user, periodic anchoring of the head hash
S9	Injection (SQL, mass assignment)	M	H	Parameterised SQL only; DTOs with Bean Validation; per-step allow-list of draft fields with length and item caps	`OnboardingUnitTest`, `SchemaMigrationTest` (`databaseRejectsInvalidValues`)	Low
S10	Server-side request forgery through push endpoints	M	H	Endpoint must be https on an allowlisted push service, default port, no credentials, length-limited; key shapes checked	`SubscriptionValidatorTest`	Low
S11	Duplicate or replayed offline saves corrupting the draft	M	M	`Idempotency-Key` with a locked profile row; same key and request replays, different request is refused; optimistic version check	`IdempotencyIntegrationTest` (five parallel identical requests apply once), `IdempotencyServiceTest`	Keys expire after 7 days; a later retry gets a version conflict instead
S12	Leaking internals in errors	M	M	One JSON error shape; expected failures are typed; unexpected ones log a traceId and return a generic 500	`HealthIntegrationTest`, manual	Low

#	Threat	L	I	Mitigation in this PoC	Evidence	Residual risk
S13	Secrets committed or weak in production	M	H	Secrets only from environment variables; production refuses to start with a short JWT secret, an invalid encryption key, missing VAPID keys, or seeding enabled	manual	Key rotation is not implemented
S14	Vulnerable dependencies	M	M	Small dependency set; unused parts of `web-push` excluded and old transitive libraries pinned to patched versions	manual	OWASP Dependency-Check and `yarn npm audit` should run in CI

Privacy (NDPA 2023)

#	Threat	L	I	Mitigation in this PoC	Evidence	Residual risk
P1	Processing without valid consent	M	H	Explicit, unticked consent with purpose text before any data is saved; submission blocked without it; timestamp and IP stored	manual	Consent versioning and withdrawal are production work (README)
P2	Exposure of identity numbers and referee contacts (database dump, backup, logs)	M	H	AES-256-GCM with a fresh IV and a per-field context; masked in responses; owner-only reveal; reviewers see referee contacts but not the national ID; never logged or audited	`OnboardingUnitTest` (`encryptionUsesRandomIv…`, `maskedValuesRoundTrip…`)	Keys cannot be rotated yet
P3	Collecting more than needed	M	M	Per-step allow-list of fields; only what the vetting purpose needs; problems reported without echoing values	`OnboardingUnitTest` (`submissionValidator… DoesNotEchoValues`)	Retention periods need legal review
P4	Reviewer notes reaching the executive	L	M	Executives never call the vetting API; they see only the status and the "more information" message	`VettingIntegrationTest` (`executivesHaveNoReviewerAccess`)	Low

#	Threat	L	I	Mitigation in this PoC	Evidence	Residual risk
P5	Personal data on a shared or lost device	M	H	Only non-sensitive draft fields stored offline, keyed to one executive; wiped on sign-out or user change; 12-hour offline window; service worker never caches API responses	`syncEngine.test.ts`	IndexedDB is not encrypted; another person using the unlocked device could read the draft
P6	Personal data disclosed through notifications	M	M	Fixed payload ("Your vetting status has been updated") with no names, status or ids; sent only for actionable changes	`VettingPushNotifierTest`	Low
P7	Right to erasure not honoured	L	H	Account deletion anonymises the user, clears draft and profile data, erases files after commit and removes push and idempotency rows; audit history is kept as a legal record	manual	Retained audit history may still identify the person; documented
P8	Cross-border transfer	M	M	Push operators receive no personal data; no other third-party processors	n/a	Hosting location and a DPIA are production decisions

Appendix A. Roles and permissions

Permission matrix

Capability	EXECUTIVE	CONSULTANT	ADMIN
Register / log in	Yes	Yes (created by Admin)	Yes (seeded)
Create / edit **own** onboarding draft	Yes	No	No
View **own** profile, documents, status, reviewer "more info" requests	Yes	n/a	n/a
Upload / download **own** documents	Yes	No	No
Submit / resubmit **own** case	Yes	No	No
View an executive's case (read-only data)	No	Only cases awaiting pickup or assigned to them (least privilege; others are 404)	Yes, any (read-only)
Download a case's documents	No	Same as viewing the case	Yes, any
See reviewer queue	No	Awaiting pickup + own cases	Yes, all cases
Change vetting status (transitions)	No	Yes	No
Add reviewer notes	No	Yes	No
Manage users (create consultants, activate / deactivate)	No	No	Yes
View full audit log + run chain verification	No	No	Yes
View audit history for a single case	No	Cases they can see (awaiting pickup or their own)	Yes
Delete **own** account	Yes	No	No

- An executive requesting another executive's resource gets **404** (avoid confirming existence). Missing role gets **403**.
- Reviewer notes are **never** visible to executives. Only the "more information required" message is.
- Admins cannot change vetting status (separation of duties).
- An admin cannot deactivate themselves.

Endpoints

Area	Endpoint	Roles
Public	`GET /api/health`, `GET /api/auth/csrf`, `POST /api/auth/register`, `POST /api/auth/login`	anyone
Session	`POST /api/auth/logout`, `GET /api/auth/me`, `POST /api/auth/password`	any signed-in
Account	`POST /api/auth/delete`	EXECUTIVE
Consent	`GET/POST /api/consent`	EXECUTIVE

Area	Endpoint	Roles
Onboarding	`GET /api/onboarding`, `PUT /api/onboarding/steps/{step}`, `POST /api/onboarding/submit`, `GET /api/onboarding/sensitive`	EXECUTIVE (own only)
Documents	`GET/POST /api/documents`, `GET /api/documents/{id}/download`, `DELETE /api/documents/{id}` (while editable; soft-delete + file erased)	EXECUTIVE (own only)
Vetting	`GET /api/vetting/queue`, `GET /api/vetting/cases/{id}`, `GET /api/vetting/cases/{id}/documents/{docId}/download`	CONSULTANT, ADMIN
Vetting	`POST /api/vetting/cases/{id}/transition`, `POST /api/vetting/cases/{id}/notes`	CONSULTANT
Push	`GET /api/push/public-key`, `POST /api/push/subscriptions` (201 new / 200 refreshed), `DELETE /api/push/subscriptions` (204, idempotent)	EXECUTIVE
Admin	`GET/POST /api/admin/users`, `PATCH /api/admin/users/{id}/active`, `GET /api/admin/audit`, `GET /api/admin/audit/verify`	ADMIN

State-changing requests need the CSRF header. Errors share one JSON shape: `timestamp`, `status`, `error`, `message`, `path`, `traceId`, plus optional `code` and `problems`.